

CUADERNILLO DE ESTUDIO

CLASE 3

*“Panorama de amenazas y
primeras herramientas de ciberseguridad”*

Profesor: Mg. Ing. Rodrigo Atilio Elgueta

Unidad: Unidad 1

Datos del/la estudiante

Nombre y apellido: _____

Grupo N.º: _____

Correo: _____

Fecha: _____

Índice

1. Panorama de amenazas para negocios digitales	2
1.1. Phishing y Spear Phishing	2
1.2. Ransomware	2
1.3. Ingeniería Social	2
1.4. Fraude y Business Email Compromise (BEC)	3
2. Herramientas gratuitas de verificación	4
2.1. Have I Been Pwned (HIBP)	4
2.2. VirusTotal	4
2.3. Gestores de Contraseñas	4
3. Estaciones Rotativas: Manos a la obra	5
4. Conformación de Grupos y TP Integrador	7
4.1. ¿En qué consiste el TP Integrador?	7
5. Glosario de la Clase 3	8
6. Espacio para notas y hallazgos	8

1. Panorama de amenazas para negocios digitales

En la clase anterior definimos qué es una **amenaza**: un evento o actor potencial que puede causar daño a un activo. Hoy vamos a conocer a los “villanos” más comunes que enfrentan los e-commerce, fintech y startups en la actualidad.

1.1 Phishing y Spear Phishing

El **Phishing** es el envío de comunicaciones masivas (correos, SMS, WhatsApp) que suplantan la identidad de una entidad confiable (un banco, Mercado Pago, Netflix) para robar credenciales o datos financieros.

El **Spear Phishing** es su versión dirigida: el atacante investiga a la víctima en redes sociales (LinkedIn, Instagram) para crear un mensaje hiper-personalizado y mucho más difícil de detectar.

Pilar CID más afectado: Confidencialidad (robo de credenciales).

1.2 Ransomware

Un software malicioso que **cifra los archivos** del servidor o las bases de datos de la empresa y exige un rescate (generalmente en criptomonedas) para devolver la clave de descifrado. Hoy suele incluir la amenaza de publicar los datos robados si no se paga (doble extorsión).

Pilar CID más afectado: Disponibilidad (el negocio se detiene) e Integridad/Confidencialidad (si hay fuga de datos).

1.3 Ingeniería Social

El arte de manipular a las personas para que revelen información confidencial o realicen acciones que comprometan la seguridad. No ataca a la máquina, **ataca al eslabón más débil: el humano**.

Ejemplo: Llamar por teléfono haciéndose pasar por “Soporte Técnico de AWS” y pedirle a un empleado junior que le dicte el código de autenticación de dos factores (2FA).

1.4 Fraude y Business Email Compromise (BEC)

El atacante se hace pasar por un directivo, proveedor o cliente legítimo para inducir una transferencia de dinero o una acción fraudulenta. En el caso BEC, se compromete el correo corporativo de un ejecutivo para enviar instrucciones falsas al área de finanzas.

Pilar CID más afectado: Confidencialidad e Integridad.

Caso: La caída de “FintechYa”

Contexto: Una fintech argentina de 20 empleados sufre un ataque de *Spear Phishing*. El atacante envía un correo al Gerente de RR.HH. con un PDF adjunto llamado “Recibos_Sueldo_Actualizados.pdf.exe”.

El error: Windows ocultaba la extensión real “.exe” y el gerente hizo doble clic.

El impacto: Se instaló un *Ransomware*. La base de datos de clientes quedó cifrada. La empresa estuvo 5 días sin poder procesar transacciones.

Consecuencias:

- **Económico:** Pérdida de u\$s 50.000 en ingresos no percibidos.
- **Reputacional:** Tendencia negativa en redes sociales por falta de respuesta.
- **Legal:** Denuncia ante la AAIP por no proteger los datos personales.

2. Herramientas gratuitas de verificación

La seguridad no es solo teoría; requiere herramientas. Hoy vamos a probar tres recursos gratuitos que todo profesional de negocios digitales debe conocer.

2.1 Have I Been Pwned (HIBP)

Web: haveibeenpwned.com

Creada por el experto Troy Hunt, esta base de datos recopila miles de millones de cuentas comprometidas en brechas de seguridad públicas. Te permite ingresar un correo electrónico o teléfono y saber si tu información estuvo expuesta en alguna filtración histórica (ej. LinkedIn, Adobe, Canva).

2.2 VirusTotal

Web: [virustotal.com](https://www.virustotal.com)

Servicio propiedad de Google que analiza archivos y URLs sospechosas utilizando **más de 70 motores de antivirus** simultáneamente (Kaspersky, Symantec, Microsoft, etc.) y servicios de sandboxing. Es ideal para verificar un enlace antes de hacer clic o un adjunto antes de abrirlo.

2.3 Gestores de Contraseñas

Ejemplos: Bitwarden, 1Password, KeePass.

El cerebro humano no puede recordar 50 contraseñas distintas, complejas y únicas. Un gestor genera, almacena y autocompleta contraseñas robustas en una bóveda cifrada. Solo necesitas recordar **una** contraseña maestra.

Regla de oro: Nunca uses la misma contraseña para tu correo corporativo/personal y para un servicio de terceros (ej. un foro o un e-commerce). Si el servicio de terceros es hackeado, los atacantes probarán esa misma clave en tu correo (técnica de *Credential Stuffing*).

3. Estaciones Rotativas: Manos a la obra

En grupos, van a rotar por tres “estaciones” (o usar sus dispositivos móviles/notebooks si el aula lo permite). En cada estación deben completar el siguiente registro.

1. Ingresen a **haveibeenpwned.com**.
2. Busquen un correo electrónico antiguo o secundario (por privacidad, eviten usar su correo institucional principal en la pantalla compartida).
3. Respondan:

¿En cuántas brechas de datos (“pwned”) apareció el correo?

Mencionen una de las empresas filtradas y qué tipo de datos se robaron (ej. contraseñas, teléfonos, direcciones).

Reflexión de negocio: Si un empleado de su empresa usa ese mismo correo y contraseña para acceder al panel de administración del e-commerce, ¿qué amenaza se materializa?

1. Ingresen a **virustotal.com**.
2. Vayan a la pestaña “URL”.
3. Analicen el siguiente enlace de prueba (simulado por la cátedra) o uno provisto por el docente:
`http://testsafebrowsing.appspot.com/apiv4/ANY/https/malware.testing.google.test/testing/phishing/`
4. Respondan:

¿Cuántos motores de seguridad marcaron la URL como maliciosa o phishing?

¿Qué categorías o etiquetas le asignaron los antivirus (ej. Phishing, Malware, Suspicious)?

Reflexión de negocio: ¿Por qué es útil integrar una API como la de VirusTotal en el sistema de atención al cliente de una fintech cuando los usuarios reportan enlaces sospechosos?

1. Abran un generador de contraseñas (puede ser el de bitwarden.com/password-generator/ o uno local).
2. Configúrenlo para generar una clave de: **16 caracteres, con mayúsculas, minúsculas, números y símbolos.**
3. Respondan:

Copien la contraseña generada (o una parte de ella):

¿Cuánto tiempo estiman que tardaría un ataque de fuerza bruta en adivinar esta clave comparado con la clave “Empresa123”?

Reflexión de negocio: ¿Qué política de seguridad implantarían en su startup respecto al uso de gestores de contraseñas para el equipo?

4. Conformación de Grupos y TP Integrador

A partir de hoy, trabajarán en grupos de 4 a 5 personas. Este grupo los acompañará hasta el final de la cursada para desarrollar el **Trabajo Práctico Integrador: “Programa de Seguridad para mi Negocio Digital”**.

4.1 ¿En qué consiste el TP Integrador?

Elegirán (o se les asignará) un negocio digital (e-commerce, fintech, app, marketplace) y construirán su dossier de seguridad con 6 entregables:

1. **Mapa de activos** y análisis CID (Unidad 1).
2. **Matriz de riesgos** y BIA simplificado (Unidad 2).
3. Evaluación de seguridad en la **nube**.
4. Cumplimiento normativo y **política de privacidad** (Unidad 3).
5. **Política de Seguridad Aceptable (PSA)** (Unidad 4).
6. **Plan de respuesta a incidentes** (verificado con IA).

Además, un **Anexo “Uso de IA”** documentando qué partes se apoyaron en IA generativa y cómo se verificó.

Completen los datos de su equipo y la idea de negocio que intentarán desarrollar (sujeta a aprobación del docente).

Nombre del Grupo / Empresa:	_____
Integrante 1:	_____
Integrante 2:	_____
Integrante 3:	_____
Integrante 4:	_____
Integrante 5 (si aplica):	_____
Idea de Negocio Digital:	

5. Glosario de la Clase 3

Término	Definición en una línea
Phishing	Suplantación de identidad para robar credenciales.
Spear Phishing	Phishing dirigido e hiper-personalizado.
Ransomware	Malware que secuestra datos cifrándolos y pide rescate.
Ingeniería Social	Manipulación psicológica del factor humano.
BEC (Business Email Compromise)	Fraude mediante suplantación de correo corporativo.
Credential Stuffing	Ataque automatizado usando contraseñas filtradas en otros sitios.
Breach (Brecha)	Incidente donde la información confidencial es expuesta.
Sandbox	Entorno aislado para ejecutar archivos sospechosos sin riesgo.
2FA / MFA	Autenticación de dos o múltiples factores (algo que sé + algo que tengo).

6. Espacio para notas y hallazgos

Anotá aquí los hallazgos más interesantes de las herramientas, ideas para tu TP Integrador o dudas para la próxima clase sobre criptografía.